RAPPORT DE TP : SUPERVISION DE SÉCURITÉ AVEC LE SIEM WAZUH

INTRODUCTION TECHNIQUE

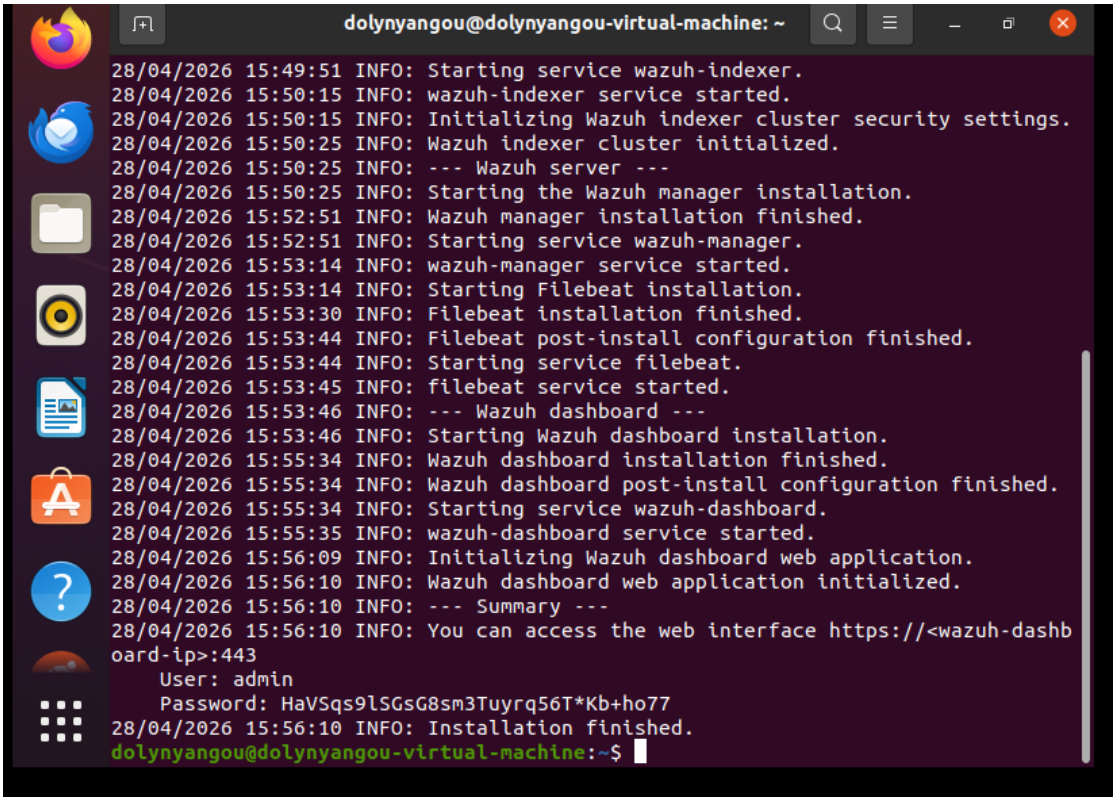
Le but de ce TP est de transformer une détection passive (voir des attaques passer) en une gestion active de la sécurité. Nous utilisons Wazuh, un SIEM (Security Information and Event Management) qui combine :

- HIDS (Host IDS) : Détection d'intrusion sur l'hôte.
- FIM (File Integrity Monitoring) : Surveillance des fichiers critiques.
- Analyse de Logs : Centralisation et corrélation des événements.

I. ÉTAPE 1 & 2 : INSTALLATION ET DÉPLOIEMENT DU SERVEUR

Nous avons utilisé une machine Ubuntu dédiée. Le script d'installation déploie l'architecture ELK (Elasticsearch, Logstash, Kibana) optimisée par Wazuh.

- Commande : sudo bash wazuh-install.sh -a

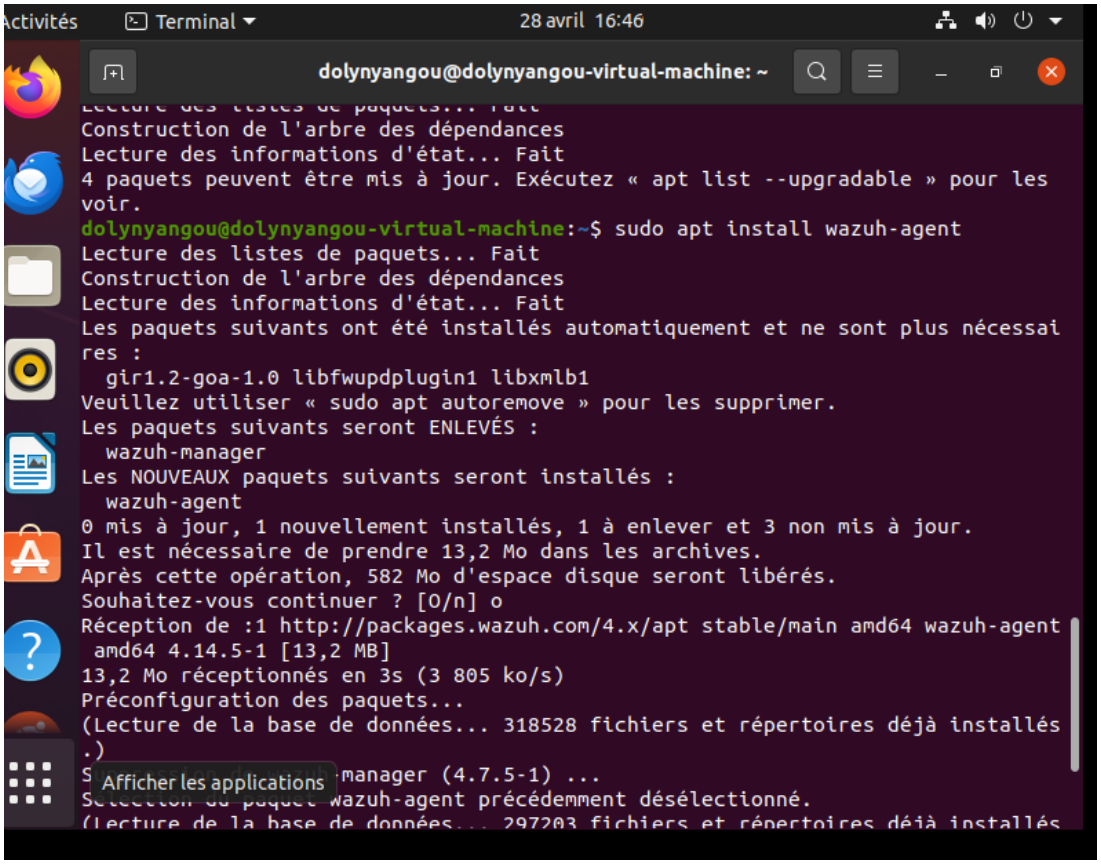


Cette image est cruciale. Elle montre que tous les services (Indexer, Manager, Dashboard) sont opérationnels. On y voit les identifiants administrateurs générés. Sans ces codes, l'accès à l'interface de gestion est impossible.

II. DÉPLOIEMENT DES AGENTS (LINUX & WINDOWS)

Un SIEM est « aveugle » s'il n'a pas d'agents. Nous avons installé l'agent Wazuh sur Ubuntu pour qu'ils rapportent tout ce qu'il se passe localement vers le serveur central.

Configuration : Modification du fichier ossec.conf pour pointer vers l'IP du serveur Wazuh sur le port 1514.



On doit voir ici l4agents Ubuntu avec le statut « Active » en vert. Cela prouve que le pare-feu laisse passer les flux de supervision et que le serveur reçoit bien les données. C'est la base de notre visibilité SOC.

III. SIMULATION D'ATTAQUE (GESTION DES COMPTES)

Un attaquant cherche souvent à créer un utilisateur pour garder un accès (persistance).

- Action Linux : sudo adduser testintrusion
- Action Windows : net user hacker Password123 ! /add

Cette capture devrais montrer l'alerte de niveau 5 (ou plus). Wazuh ne se contente pas de voir la commande, il décode le log système. On peut y voir l'heure exacte et quelle machine a été touchée. C'est la preuve que le SIEM surveille les actions administratives suspectes.

IV. ÉTAPE 7 : SURVEILLANCE D'INTÉGRITÉ (FIM)

Nous surveillons le fichier /etc/passwd qui contient la liste des utilisateurs.

- Action : Ajout d'une ligne dans /etc/passwd.

Ici, Wazuh doit afficher une alerte de changement. Le SIEM a calculé le checksum (hash) du fichier et a vu qu'il a changé. Cela permet de détecter si un malware ou un attaquant tente de modifier la configuration profonde du système.

V. CORRÉLATION RÉSEAU AVEC KALI (L'ANALYSE FINALE)

Nous lançons un scan Nmap depuis Kali : nmap -sS [IP].

Ca dit etre la capture la plus importante. On y voit deux types d'alertes en même temps :

- ✓ L'alerte réseau : Suricata détecte le scan de ports.
- ✓ L'alerte système : L'agent Wazuh sur la cible voit des tentatives de connexion ou des erreurs de logs.

Analyse : Le SIEM permet de lier ces deux événements. L'analyste peut dire : « L'IP de Kali a scanné notre serveur, puis a essayé de créer un utilisateur ». C'est ce qu'on appelle la corrélation d'événements.

CONCLUSION ET AMÉLIORATIONS SOC

Ce TP démontre qu'une défense efficace repose sur la centralisation.

Propositions d'améliorations pour le poste SOC :

- Réponse Active : Configurer Wazuh pour bannir (block) automatiquement l'IP de Kali via le pare-feu dès qu'un scan Nmap dépasse 10 ports.
- Tableaux de bord personnalisés : Créer une vue spécifique pour les tentatives de connexion « Brute Force » sur le protocole SSH.
- Vulnerability Detection : Activer le module de détection de vulnérabilités pour voir quels logiciels sur Ubuntu ou Windows ne sont pas à jour.